

Data Sanitisation Techniques

- Overwriting
- Cryptographic erasure
- Degaussing
- Physical destruction
- Firmware commands
- Remote sanitisation

relevant references: NIST SP 800-88, IEEE 2883, and NSA/CSS standards.



Key Definitions & Terminology

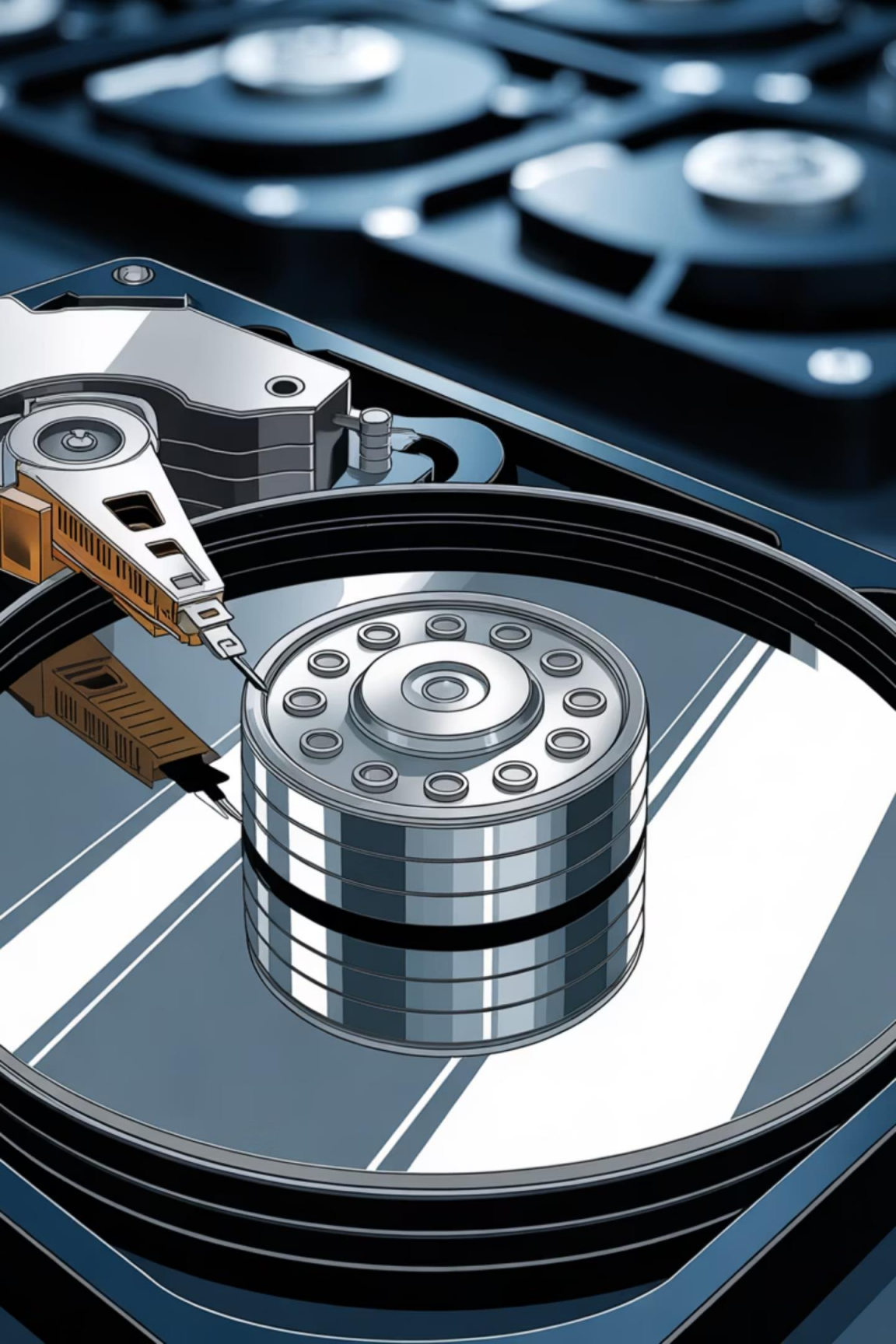
Core concepts referenced throughout this presentation (1/2)

1	NIST Clear Logical techniques (e.g. overwriting) that protect against simple, non-invasive data recovery. Applies to media that will remain within the same security environment. Defined in NIST SP 800-88.
2	NIST Purge More rigorous techniques (e.g. cryptographic erasure, degaussing, firmware commands) that protect against laboratory-grade recovery attacks. Required before media is released outside a controlled environment. Defined in NIST SP 800-88.
3	NIST Destroy Physical destruction rendering media completely unusable and unrecoverable. Includes disintegration, incineration, and shredding to specified particle sizes. Defined in NIST SP 800-88.
4	DEK (Data Encryption Key) The symmetric key used to encrypt data at rest on a storage device. Destroying the DEK is the basis of Cryptographic Erasure.
5	SED (Self-Encrypting Drive) A storage device with built-in hardware encryption. Supports native Crypto-Erase via ATA Secure Erase command.
6	Wear Levelling An SSD firmware mechanism that distributes writes across NAND cells to extend lifespan. Can cause overwriting to be incomplete, as data may persist in unmapped cells.

Key Definitions & Terminology

Core concepts referenced throughout this presentation (2/2)

1	Coercivity (Oe) A measure of a magnetic medium's resistance to demagnetisation, expressed in oersteds. Degaussers must be rated at or above the target medium's coercivity to be effective.
2	Chip-off Forensics A physical recovery technique where NAND flash chips are removed from a device and read directly, bypassing the controller. Relevant to SSD destruction particle size requirements.
3	MDM (Mobile Device Management) Enterprise software platform used to manage and remotely wipe mobile endpoints. Wipe effectiveness depends on device connectivity at time of command.
4	FIPS-approved RNG A random number generator validated under FIPS 140-2/3. Required by IEEE 2883 for generating replacement encryption keys during Crypto-Erase.
5	NVM (Non-Volatile Memory) A type of storage that retains data without power. Encompasses NAND flash (used in SSDs, USB drives, and memory cards) and NOR flash. The NVMe (Non-Volatile Memory Express) protocol is designed specifically to interface with NVM over PCIe, offering lower latency than ATA/SATA interfaces.
6	LTO Tape (Linear Tape-Open) A magnetic tape storage format widely used for backup and archival. Supports high-capacity sequential storage. Sanitisation options are limited: overwriting achieves NIST Clear; degaussing achieves NIST Purge. Crypto-Erase is applicable only if data was encrypted at rest prior to storage.



Overwriting

- Writes one or more data patterns to all addressable storage locations through the standard write interface.
- For modern magnetic HDDs, a single pass of pseudorandom data or the fixed pattern `0x00` satisfies NIST Clear and, in many cases, Purge requirements.
- **ATA Security Erase Unit:** preferred method. It invokes the drive's internal firmware routine and can reach reallocated sectors the OS file system cannot address.
- **Limitation: SSDs:** overwriting is not forensically sound unless the full physical address space is exposed.
- Wear-levelling can leave prior content intact in another NAND cell cluster. Use firmware-level commands (ATA Sanitize, NVMe Sanitize) for complete physical coverage.

ATA Security Erase Unit

The preferred method: invokes the drive's internal firmware routine, addressing reallocated sectors inaccessible through the OS file system — something software-level block writes cannot guarantee.

Limitation: SSDs

Overwriting is not forensically sound for SSDs unless the full physical address space is exposed. Wear-levelling means a write to LBA 0 may leave previous content intact in another NAND cell cluster. Only firmware-level commands (ATA Sanitize, NVMe Sanitize) guarantee complete physical coverage.

Degaussing

Degaussing exposes magnetic media to a powerful, rapidly alternating electromagnetic field, randomising the magnetic domains that encode binary data. It is irreversible and renders the medium inoperable — servo tracks used by HDD firmware to position the read/write head are destroyed alongside all data.

Coercivity Requirements

- Degaussers must match the coercivity rating (oersteds, Oe) of the target media.
- Modern high-density HDDs typically require **3,000–5,000 Oe**.
- A degausser rated below the medium's coercivity is ineffective.
- Approved devices are listed on the NSA/CSS Evaluated Products List (EPL).

Applicability & Limitations

- Effective for magnetic HDDs, LTO tapes, and legacy floppy disks.
- No software interaction is required.
- **No effect** on SSDs, optical media, or any non-magnetic storage.
- Suitable as a standalone Purge-level technique for magnetic media when followed by verification.

Cryptographic Erasure (Crypto-Erase)

- Cryptographic Erasure makes data unrecoverable by destroying the encryption key instead of overwriting the data.
- It is valid only when data was encrypted at rest using **AES-256 minimum**, with key material stored separately.
- After key destruction, ciphertext becomes computationally indistinguishable from random noise.

NIST & IEEE Classification

- NIST SP 800-88 classifies Crypto-Erase as a **Purge-level** technique.
- IEEE 2883 also requires the old DEK to be overwritten with random data.
- Replacement key generation must use a FIPS-approved RNG.

Self-Encrypting Drives (SEDs)

- SEDs implement this natively.
- ATA Secure Erase generates a new internal Data Encryption Key (DEK).
- This makes previously encrypted data permanently unreadable.
- It is ideal for SSDs, cloud storage, and enterprise arrays where direct physical overwriting is impractical.

Physical Destruction

Physical destruction makes a storage medium unable to yield data. Choose the method based on media type, classification level, and regulatory requirements.

Disintegration

- High-torque shredders reduce HDDs, SSDs, and optical disks to particles.
- NSA/CSS EPL requires $\leq 2 \text{ mm} \times 2 \text{ mm}$ particles for TOP SECRET HDD media.

Shredding

- NIST SP 800-88 mandates particles $\leq 1 \text{ mm} \times 5 \text{ mm}$ for SSDs and flash.
- This ensures NAND die fragmentation and blocks chip-off forensic recovery.

Incineration

- Temperature-controlled incineration achieves total material destruction.
- Used for optical disks, paper-based media, and as a secondary measure post-degaussing.

Drilling / Crushing

- Bench-top devices support on-site field sanitisation of HDDs.
- They are less thorough than shredding.
- NSA EPL does not list most such devices for classified media.

ATA Firmware Sanitisation Commands

Modern ATA (SATA) drives expose two firmware-level sanitisation methods below the OS layer.

Security Erase Unit (ATA 0xF4, Enhanced)



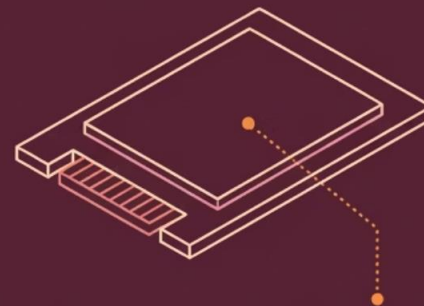
Drive-internal overwrite of all user data and reallocated sectors.

Sanitize Overwrite Ext



Repeated overwriting of the entire media.

Sanitize Block Erase Ext (for SSDs)



Block-erase command sent to all NAND dies.

Sanitize Crypto Scramble Ext



Re-keys internal DEK (Data Encryption Key).

Security Erase Unit

- ATA command `0xF4` (Enhanced mode)
- Performs a drive-internal overwrite of all user data and reallocated sectors
- Preferred over OS-level block writes

ATA Sanitize Device (ACS-2)

- **Overwrite Ext:** Repeated pattern overwriting
- **Block Erase Ext:** Recommended for SSDs; signals block-erase to all NAND dies
- **Crypto Scramble Ext:** Re-keys the internal DEK

NVMe Sanitisation Commands

- NVMe drives implement the **NVM Express Sanitize** command.
- It operates at the NVM subsystem level.
- It covers namespaces, metadata, and over-provisioned space.
- ATA-level commands may not reach these areas.

NVMe Sanitize Operations

- **No-Dealloc Overwrite:** Pattern-based overwrite across all NVM space
- **Block Erase:** Hardware-level erase of all NAND blocks
- **Cryptographic Erase:** Re-key of internal encryption material

Critical Compliance Detail

- Controllers must set the **NODMMAS** bit correctly.
- **NODMMAS** means No-Deallocate Modifies Media After Sanitize.
- This ensures deallocated LBAs are also sanitised.
- It helps prevent residual data in over-provisioned or deallocated NAND regions.



Remote Sanitisation & MDM

Mobile Device Management (MDM) platforms can issue remote wipe commands to smartphones, tablets, and corporate-managed endpoints.

- Useful for lost or decommissioned devices.
- iOS remote wipe regenerates the file system encryption key.
- This is equivalent to a Cryptographic Erase.
- Android (FDE/FBE) behaves analogously.

Platform Behaviour

- **iOS:** Remote wipe regenerates the file system encryption key — equivalent to a Cryptographic Erase
- **Android (FDE/FBE):** Google's Full Disk Encryption and File-Based Encryption implementations behave analogously

Forensic Soundness Caveats

- Effectiveness depends on the device being powered on and network-reachable.
- The wipe command must be acknowledged before confiscation or power-off.
- MDM wipes are a risk-mitigation measure, not a deterministic sanitisation guarantee.

Technique Comparison by Media Type

- Choose the sanitisation method based on the media type and assurance level.
- No single technique works for every storage medium.
- Match the method to the device and the required outcome.

Technique	Magnetic HDD	SSD / Flash	LTO Tape	Optical	Mobile
Overwriting	Clear/Purge	Partial	Clear	✗	✗
Crypto-Erase	SEDs only	Purge	If encrypted	✗	iOS/Android
Degaussing	Purge	✗	Purge	✗	✗
Physical Destruction	Destroy	Destroy	Destroy	Destroy	Destroy
ATA/NVMe Firmware	Purge	Purge	✗	✗	✗

Verification & Certification

Sanitisation without verification is not forensically sound — NIST SP 800-88

Verification Methods

Read Verification

After overwriting, a tool reads a statistically significant sample of sectors and confirms the written pattern is present. 100% read-verify is preferred; 10% sampling is common in high-throughput environments.

Hash-Based Verification

A cryptographic hash (SHA-256 or SHA-3) of the drive is computed before and after sanitisation. Post-sanitisation, the hash of a zeroed drive must match the expected null-byte hash for that capacity.

Firmware-Reported Success

ATA and NVMe commands return a status register. The SANITIZE STATUS log page (NVMe) or SECURITY STATUS word (ATA) must be examined post-completion. A success code is necessary but not sufficient - combine with a read-verify sample.

Third-Party Forensic Verification

For high-assurance or litigation-context sanitisations, an independent forensic examiner uses court-admissible tools (EnCase, FTK, Autopsy with write-blocked access) to attempt data recovery and document results.

Audit Trails & Chain of Custody

Audit Trail — Required Documentation

- Asset identifier (serial number, make, model)
- Data classification of the content
- Sanitisation method and tool used (including software version)
- Date, time, and operator identity
- Verification result
- Final disposition (reuse, transfer, or destruction)

Physical Destruction

- A destruction certificate must be issued and signed by an authorised witness
- Many organisations require Dual-Person Integrity (DPI): two authorised individuals independently witness and co-sign the destruction record
- Mirrors the principle used in cryptographic key ceremonies

Retention Requirements

- Chain-of-custody records must be retained for the period mandated by the applicable regulatory framework
- Minimum 3 years under PCI DSS
- Minimum 7 years under many financial regulations